5. Software Composition Analysis (SCA) and SBOM using FOSSA

Aim

To perform Software Composition Analysis (SCA) using FOSSA to identify open-source dependencies, security vulnerabilities, and license compliance issues, and to generate SPDX and CycloneDX SBOMs.

Procedure

1. Open PowerShell as Administrator and install the FOSSA CLI.
2. Verify that FOSSA CLI has been installed successfully.
3. Create a FOSSA account and generate a Full Access API token from the account settings.
4. Configure the API token in PowerShell.
5. Create a sample project and add an open-source dependency with a known vulnerability.
6. Navigate to the project directory and perform dependency analysis using FOSSA.
7. Run the FOSSA test to identify security vulnerabilities and license-related issues.
8. Open the FOSSA web dashboard and select the analyzed project. Review the Vulnerabilities section for CVE details, severity, affected packages, and remediation recommendations.
9. Review the Licenses section to identify license types and possible compliance issues.
10. Generate an SPDX SBOM using the FOSSA CLI and save it in text and JSON formats.
11. Open the FOSSA dashboard and navigate to Reports > SBOM. Select CycloneDX and download the SBOM in JSON or XML format.
12. Examine both SBOM files and compare their package names, versions, licenses, and dependency relationships.

Commands

```
Set-ExecutionPolicy Bypass -Scope Process -Force; iex ((New-Object System.Net.WebClient).Downloads
fossa --version
$env:FOSSA_API_KEY="YOUR_FULL_ACCESS_API_KEY"
mkdir fossa-lab
cd fossa-lab
npm init -y
npm install lodash@4.17.20
fossa analyze
fossa test
fossa report attribution --format spdx
fossa report attribution --format spdx > sbom-spdx.txt
fossa report attribution --format spdx-json > sbom-spdx.json
```

Output

1. FOSSA CLI Installation and Version Check

[Insert your screenshot here]

2. Dependency Analysis (fossa analyze)

[Insert your screenshot here]

3. Web Dashboard Compliance & Security Overview

[Insert your screenshot here]

4. SPDX Report Generation

[Insert your screenshot here]

5. Dashboard SBOM Report Preview

[Insert your screenshot here]

Result

The sample project was successfully analyzed using FOSSA SCA. The open-source dependencies, security vulnerabilities, CVE details, and license information were identified. SPDX and CycloneDX SBOMs were successfully generated and examined, providing information about the project's software components, versions, licenses, and dependency relationships.